SOC Level 3: Advanced Threat Intelligence & Cyber Kill Chain Analysis

Course: Security Operations Center (SOC)
Module: Advanced Persistent Threat (APT) Simulation & Mitigation

Table of Contents

1. **Lab Overview & Learning Objectives**
2. **Scenario: Operation "Crimson Dawn" - An APT Simulation**
3. **Lab Architecture & Introducing the SIEM**
4. **Part 1: The Initial Breach - Weaponization & Delivery**
5. **Part 2: Establishing Foothold - Exploitation & Persistence**
6. **Part 3: Lateral Movement & Privilege Escalation**
7. **Part 4: Data Exfiltration & The Command & Control (C2) Channel**
8. **Part 5: Strategic Countermeasures & Threat Intelligence Integration**
9. **The Final Brief: CISO & Board-Level Report**
10. **Lab Challenge & Strategic Analysis Questions**

Lab Overview & Learning Objectives

Welcome, Senior Analysts. You are no longer just handling alerts; you are leading the investigation into a sophisticated, multi-stage attack campaign. Your ability to connect the dots, use advanced tools, and think like an adversary will be critical.

By the end of this lab, you will be able to:

- **Map** security events to the MITRE ATT&CK® framework.
- **Utilize** Wazuh's Vulnerability Detection module to prioritize risks.
- **Analyze** network-based evidence alongside host-based logs.
- **Construct** complex Wazuh rules to detect TTPs (Tactics, Techniques, and Procedures).
- **Integrate** external threat intelligence (TI) feeds into your monitoring.
- **Articulate** the business impact of an incident to executive leadership.

Scenario: Operation "Crimson Dawn" - An APT Simulation

Background: A fictional hacktivist group, "Crimson Dawn," has targeted your organization. Their goal is to steal sensitive intellectual property and leak it publicly to damage your company's reputation.

The Kill Chain Unfolds:

1. **Reconnaissance:** (Already occurred) They've identified a vulnerable web server in your DMZ.
2. **Weaponization & Delivery:** They crafted a malicious PDF document containing an exploit.
3. **Exploitation & Installation:** The exploit drops a persistent backdoor on the server.
4. **Command & Control (C2):** The backdoor beacons out to a simulated C2 server.
5. **Lateral Movement:** The attacker moves from the web server to a more valuable internal workstation (your Lab 1 Windows agent).
6. **Data Exfiltration:** They locate and compress sensitive data from the workstation for exfiltration.

Your Mission: You are the lead investigator. You must uncover each stage of this attack, understand the TTPs used, and recommend long-term defensive improvements. **Lab Architecture & Introducing the SIEM**

- **Wazuh Manager (Ubuntu):** Now also acts as a **syslog server** and will receive logs from a second, "compromised" Ubuntu server.
- **New! Web Server (Ubuntu VM):** A second Ubuntu VM with a vulnerable service (e.g., a legacy FTP server or a deliberately old WordPress installation). This server will have a Wazuh agent installed.
- **Windows-SOC-Lab Agent (Windows Host):** Your original endpoint, now the target of lateral movement.

Part 1: The Initial Breach - Weaponization & Delivery

Simulated on the "Web Server" VM.

1. **Simulate the Attack:**
   - On the Web Server VM, use a tool like telnet or nmap to simulate a port scan from an external IP against the Windows host. This creates a reconnaissance log.

```
icdfa-server@icdfa-server:~$ nmap -Pn 192.168.0.140
Starting Nmap 7.80 ( https://nmap.org ) at 2026-03-01 15:03 UTC
Nmap scan report for 192.168.0.140
Host is up (0.00069s latency).
Not shown: 997 filtered ports
PORT    STATE SERVICE
135/tcp open  msrpc
139/tcp open  netbios-ssn
445/tcp open  microsoft-ds

Nmap done: 1 IP address (1 host up) scanned in 4.68 seconds
icdfa-server@icdfa-server:~$ _
```

   3 ports were open on the window host ip.

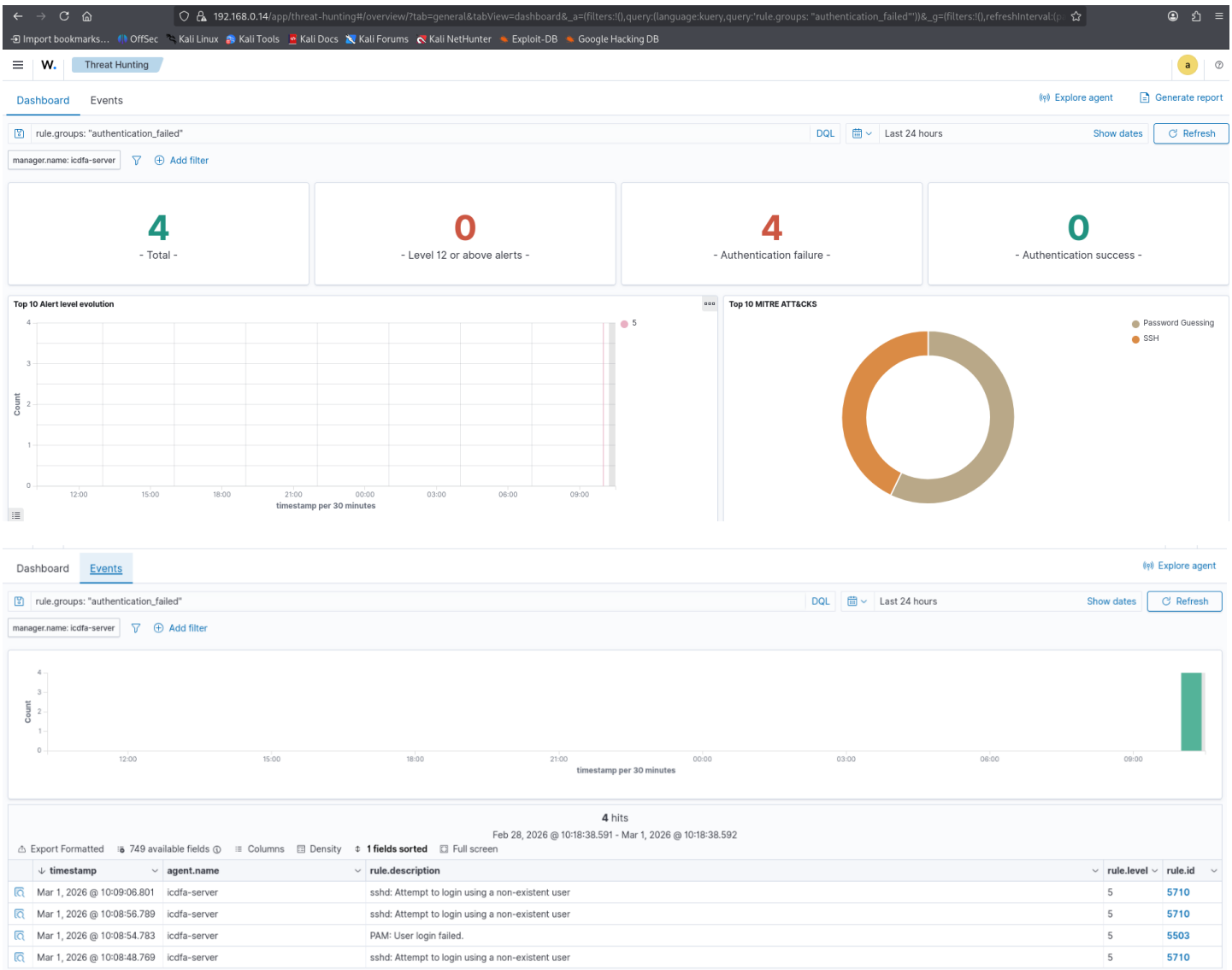
   - Generate a failed login attempt log on the Web Server itself (e.g., a failed SSH login).

```
icdfa-server@icdfa-server:~$ ssh fakeuser@192.168.0.14
The authenticity of host '192.168.0.14 (192.168.0.14)' can't be established.
ECDSA key fingerprint is SHA256:lGE/crT+LhdPbGsw7FgS52ENAYxWOaYeFIg+YBPBba0.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.0.14' (ECDSA) to the list of known hosts.
fakeuser@192.168.0.14's password:
Permission denied, please try again.
fakeuser@192.168.0.14's password:
Permission denied, please try again.
fakeuser@192.168.0.14's password: _
```

Permission denied

2. **Hunt for Reconnaissance:**

   - In the Wazuh Dashboard, create a new **WQL query** that looks for rule.groups: "authentication_failed" from the Web Server agent.



   - **MITRE ATT&CK Mapping:** Tag this activity as **T1595 - Scanning IP Blocks** and **T1110 - Brute Force**.

Attack Activity	Mapped MITRE ATT&CK Technique
Failed SSH logins	T1110 – Brute Force
Port scan	T1595-Active scanning

The failed SSH login attempts indicate repeated password-guessing attempts. This behavior aligns directly with MITRE ATT&CK technique T1110 (Brute Force), specifically sub-technique T1110.001 (Password Guessing).

There are 3 active port opened on the host ip.

Part 2: Establishing Foothold - Exploitation & Persistence

Simulated on the "Web Server" VM.

1. **Simulate the Exploit & Backdoor:**

   - On the Web Server VM, create a suspicious file in /tmp with a name like ...pdf.exe (a classic e vasion technique).

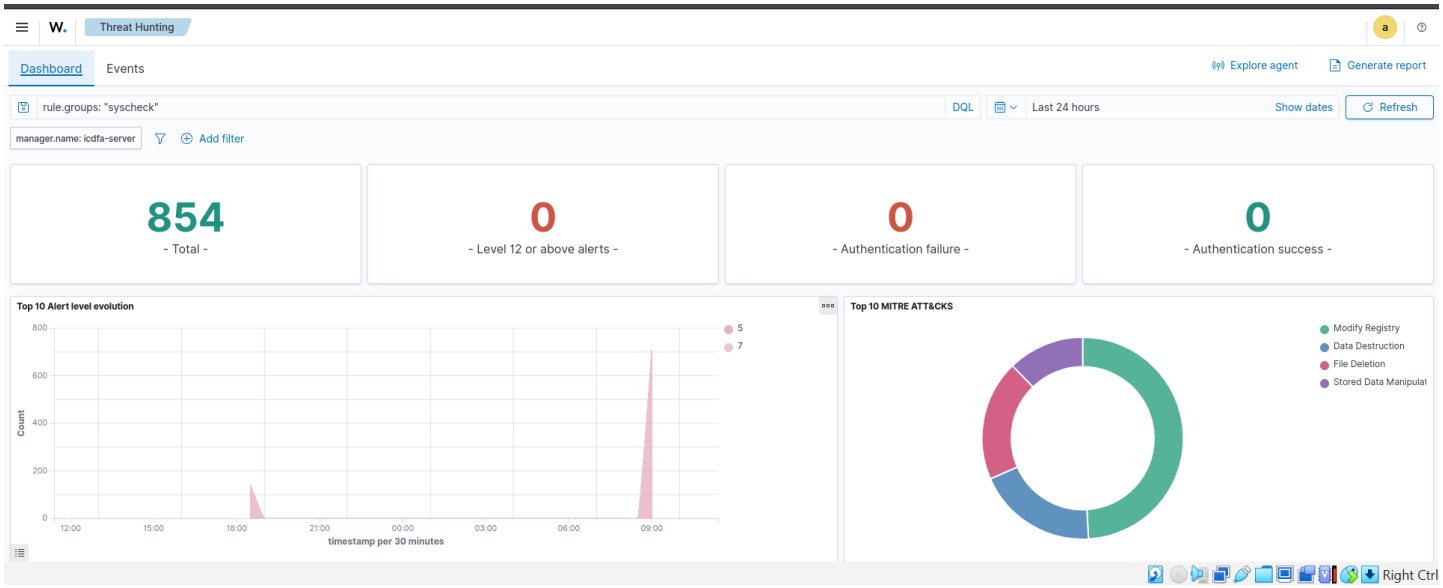
```
icdfa-server@icdfa-server:~$ sudo touch /tmp/invoice.pdf.exe
[sudo] password for icdfa-server:
icdfa-server@icdfa-server:~$ sudo chmod +x /tmp/invoice.pdf.exe
icdfa-server@icdfa-server:~$
```

   - Create a new cron job for the root user that executes a script every minute (simulating persistence). The command could be as simple as echo "C2 Check-in" >> /tmp/.hiddenlog.

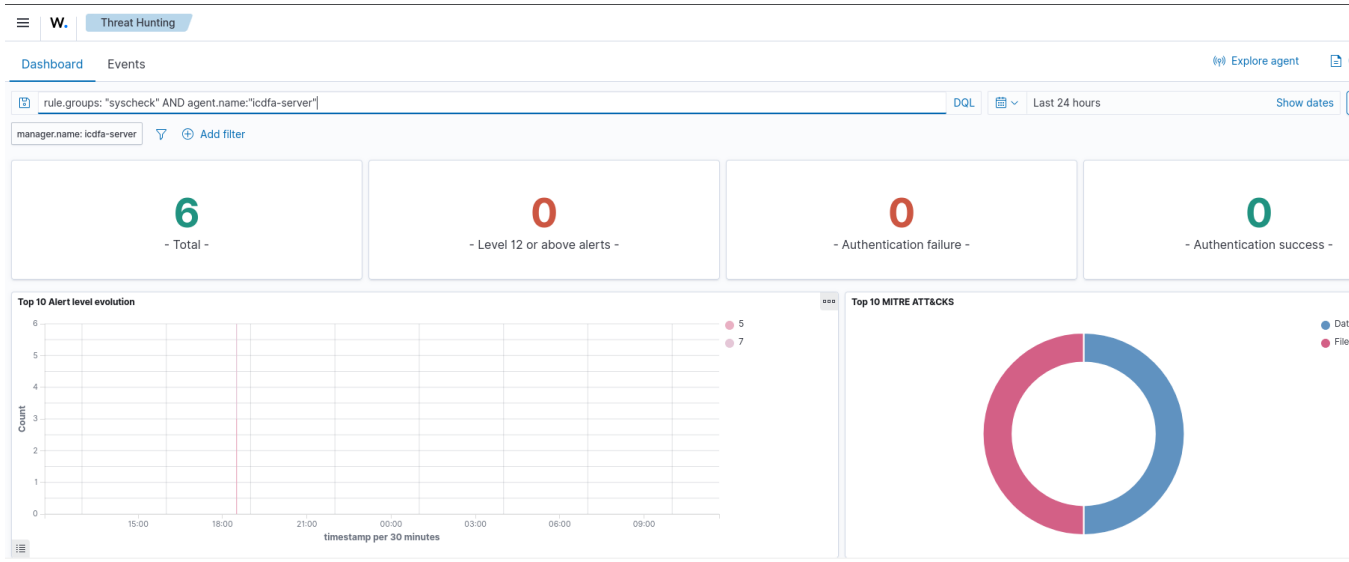
```
root@icdfa-server:~# sudo touch /tmp/invoice.pdf.exe
root@icdfa-server:~# sudo chmod +x /tmp/invoice.pdf.exe
root@icdfa-server:~# echo "* * * * * root echo 'C2 Check-in' >> /tmp/.hiddenlog" | sudo tee /etc/cron.d/persiste
* * * * * root echo 'C2 Check-in' >> /tmp/.hiddenlog
root@icdfa-server:~# cat /etc/cron.d/persistence
* * * * * root echo 'C2 Check-in' >> /tmp/.hiddenlog
root@icdfa-server:~# cat /tmp/.hiddenlog
C2 Check-in
C2 Check-in
root@icdfa-server:~# cat /tmp/.hiddenlog
C2 Check-in
C2 Check-in
C2 Check-in
root@icdfa-server:~# cat /tmp/.hiddenlog
C2 Check-in
C2 Check-in
C2 Check-in
root@icdfa-server:~#
```

2. **Hunt for Persistence:**

   - In the Wazuh Dashboard, search for events from the Web Server agent with rule.groups: "syscheck" and look for the alert for the new file in /tmp.



- Search for events where data.win.system.eventID: 4698 (Scheduled Task Created - Windows equivalent) or on Linux, look for logs related to cron.



- **MITRE ATT&CK Mapping:** Tag this as **T1053.003 - Scheduled Task/Job: Cron** and **T1036 - Masquerading**.

Part 3: Lateral Movement & Privilege Escalation

Simulated from the "Web Server" to the "Windows" agent.

1. **Simulate Lateral Movement:**
   - From the Web Server VM, use a tool like psexec.py (from the Impacket suite) or simply simulate it by using the Windows "net use" command from a script to attempt a connection to the Windows host's ADMIN$ share. This will generate Windows security event logs (4624, 4625, 5140).
2. **Hunt for Lateral Movement:**
   - In the Wazuh Dashboard, create a **correlation query**:

(data.win.system.eventID: 4624 AND logon.process: "psexec") OR (data.win.system.eventID: 5140)

- This looks for successful logons via PsExec or network share access.
- **MITRE ATT&CK Mapping:** Tag this as **T1021.002 - Remote Services: SMB/Windows Admin Shares**.

Part 4: Data Exfiltration & The C2 Channel *Simulated*

on the "Windows" agent.

1. **Simulate Data Theft:**
   - On your Windows host, use 7z or rar from the command line to compress the entire SensitiveFiles folder into a password-protected archive. This simulates data staging.
   - Use a command like curl or Invoke-WebRequest in PowerShell to "send" this archive to an external IP address (you can use a dummy address or your Ubuntu VM's IP to simulate the C2 server).
2. **Hunt for Data Exfiltration:**
   - In the Wazuh Dashboard, search for events from the Windows agent with data.win.system.eventID: 1 (Sysmon process creation) and the command line containing 7z.exe, rar.exe, or curl.exe.
   - Look for network connection events from the Windows agent to the "suspicious" external IP.
   - **MITRE ATT&CK Mapping:** Tag this as **T1560.001 - Archive Collected Data: Archive via Utility** and **T1041 - Exfiltration Over C2 Channel**.

Part 5: Strategic Countermeasures & Threat Intelligence Integration

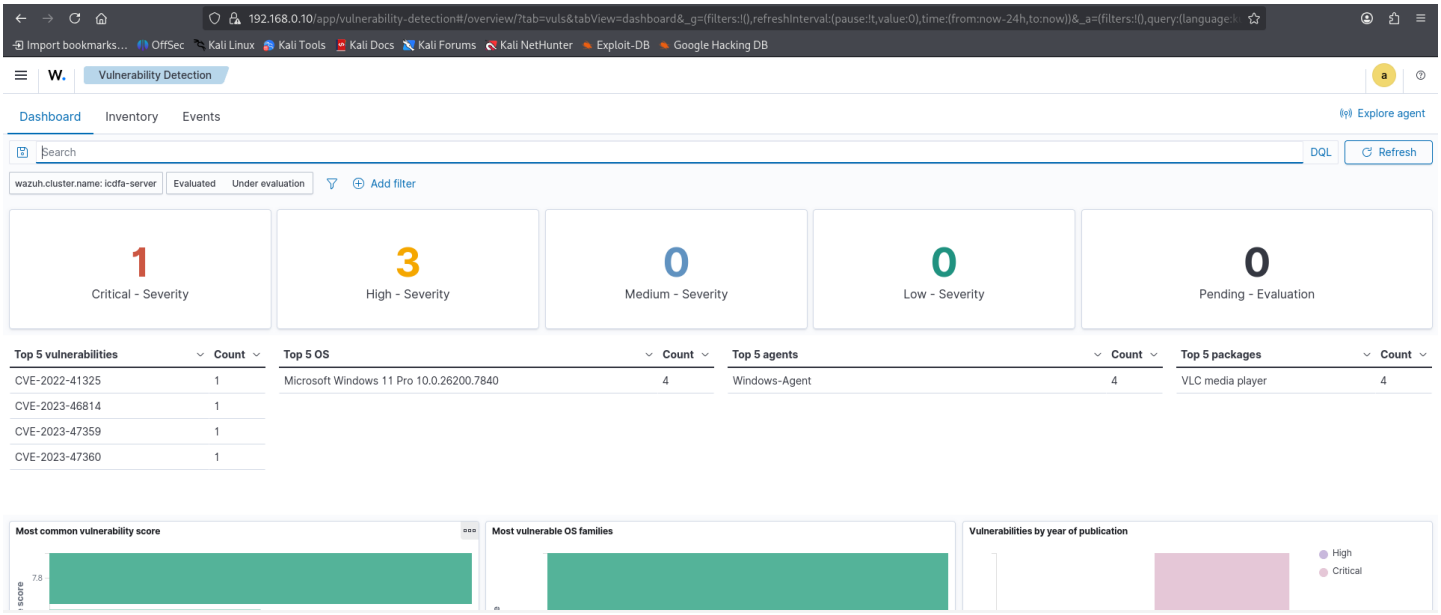
1. **Create a Custom Rule:**
   - The attacker's IP address used for C2 (192.168.1.200) is now known. On the **Wazuh Manager**, create a custom rule to generate a high-alert for any communication with this IP.
   - Edit /var/ossec/etc/rules/local_rules.xml and add:

xml

```
<group name="local_threat_intel,">
  <rule id="100001" level="12">
    <if_group>web</if_group>
    <match>$IP_FOUND_HERE$</match> <!-- Replace with the C2 IP -->
    <description>Connection to known malicious IP (Crimson Dawn C2).</description>
<mitre>
```

```
    <id>T1071.001</id> <!-- Application Layer Protocol -->
  </mitre>
 </rule>
</group>
```

- Restart the Wazuh manager.

2. **Leverage Vulnerability Detection:**

   - Use Wazuh's built-in Vulnerability Detector on the manager to scan the Web Server VM. The goal is to identify the hypothetical vulnerable service that was exploited.
   - Navigate to the **Security Events** tab and filter by rule.groups: "vulnerability-detector" to see the results.